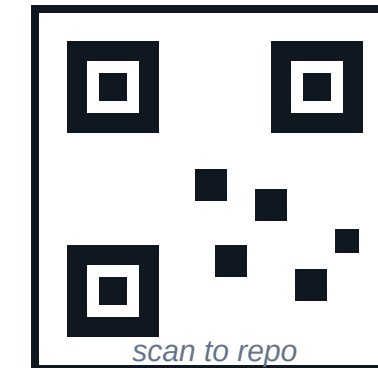


Static Security Analysis of AWS IAM Policies for AI Workload Identities



Detecting Excessive Privilege and Identity-Pivot Risks Before Deployment

Pooja Kiran

Security Engineering • AI / Agent Security • Cloud Security

MIT • Python 3.12 • HEAD e1f19cd • verified 2026-09-26

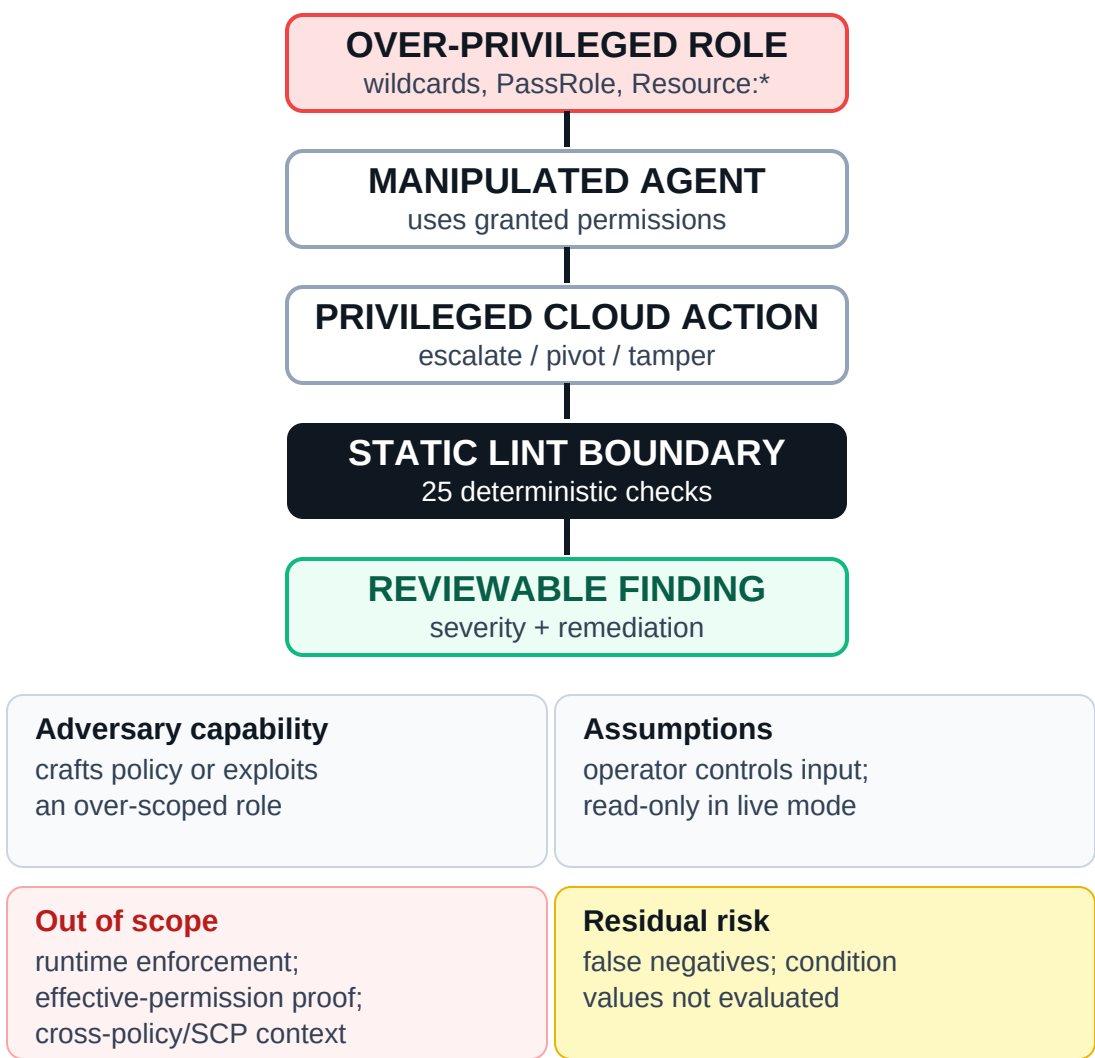
RESEARCH QUESTION

Can dangerous IAM patterns in AI-agent roles be identified before deployment through deterministic, non-executing policy analysis?

01 • THE FAILURE MODE

AI agents and tool executors assume IAM roles. An over-broad role turns a manipulated agent into real cloud actions: invoke Lambda, assume roles, change Bedrock/SageMaker control planes, read secrets, or disable CloudTrail. The risk exists at deploy time, before any runtime monitoring sees a single call.

02 • THREAT MODEL

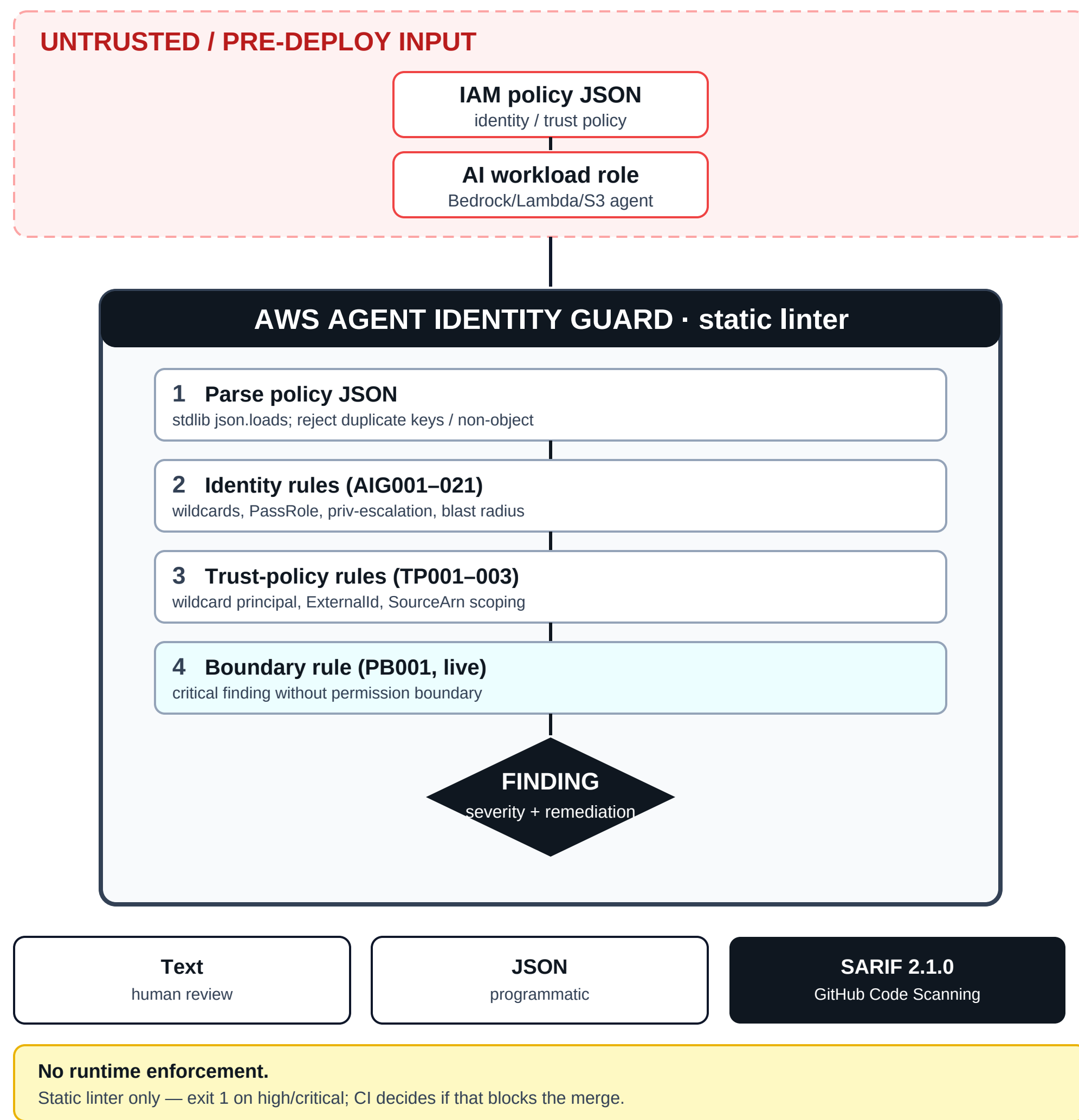


03 • OBJECTIVE

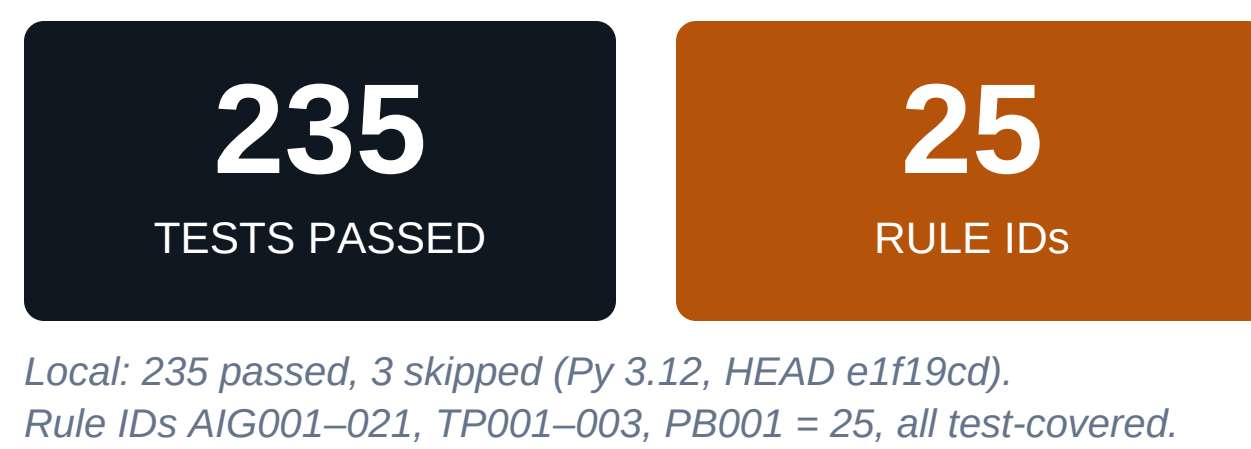
Determine whether deterministic rules can flag agent-specific IAM risk patterns pre-deploy, emitting CI-gating findings in text, JSON, and SARIF.

- 01 – 25 rules: identity, trust, boundary
- 02 – Severity + remediation per finding
- 03 – SARIF 2.1.0 + CI exit codes
- 04 – Optional read-only live account scan

HERO • STATIC IAM LINT PIPELINE



RESULTS • CURRENT LOCAL VALIDATION



Verified surface	
Output formats	3
SARIF version	2.1.0
Local benchmark p95	0.69ms

RULE SEVERITY MIX

CRITICAL (8 rules)		32%
HIGH (10 rules)		40%
MEDIUM (7 rules)		28%

Severity distribution across the 25 rule IDs. Counts from README rule table.

HISTORICAL CI + BENCHMARK

Main CI 35808439923 (001fb2c, 2026-09-23):
231 passed, 3 skipped. Perf gate: 1.10ms p95,
1,913 policies/sec — CI-gate thresholds, not SLOs.

NOT ESTABLISHED BY THIS REPO

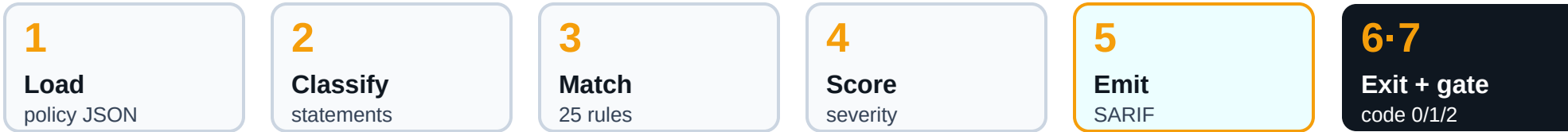
Effective permissions or proof an exploit chain is reachable. Runtime deny. Cross-policy/SCP context.

SECURITY BOUNDARY

PROTECTS / DETECTS	DOES NOT ESTABLISH
- pre-deploy policy review - wildcard / PassRole - audit-tamper actions - weak trust policies (advisory)	- runtime API enforcement - effective-permission computation - SCP / boundary interaction

Figure 1. Static lint pipeline: parse → 25 deterministic rules → severity/remediation → text/JSON/SARIF → CI gate

METHOD • RULE EVALUATION



CONTRIBUTION

A deterministic, non-executing IAM linter specialized for AI-agent roles — 25 rules spanning identity, trust, and permission-boundary risks, emitting SARIF for CI gating. Intentionally narrower than account-wide posture tools; complements Access Analyzer.

IDENTITY ≠ AUTHORIZATION

LIMITATIONS

1. Static analysis only — no runtime enforcement.
2. No semantic evaluation of Condition key values.
3. Single-policy scope; no SCP/boundary interaction.
4. Prefix-based action matching may miss new namespaces.
5. False negatives accepted; not a full IAM engine.

FUTURE WORK

- Cross-policy / SCP-aware evaluation.
- Condition-value semantic analysis.
- Broader live-account coverage.
- Effective-permission integration (Access Analyzer).
- Expanded namespace / action catalog.

CONCLUSION

The linter flags agent-specific IAM risk pre-deploy with deterministic rules and SARIF output. Local tests cover all 25 rule IDs. It does not compute effective permissions or enforce at runtime — use alongside IAM Access Analyzer and CloudTrail for that.

REPRODUCE

```
PYTEST_DISABLE_PLUGIN_AUTOLOAD=1 pytest tests -q  
aws-agent-identity-guard policy.json --format sarif
```